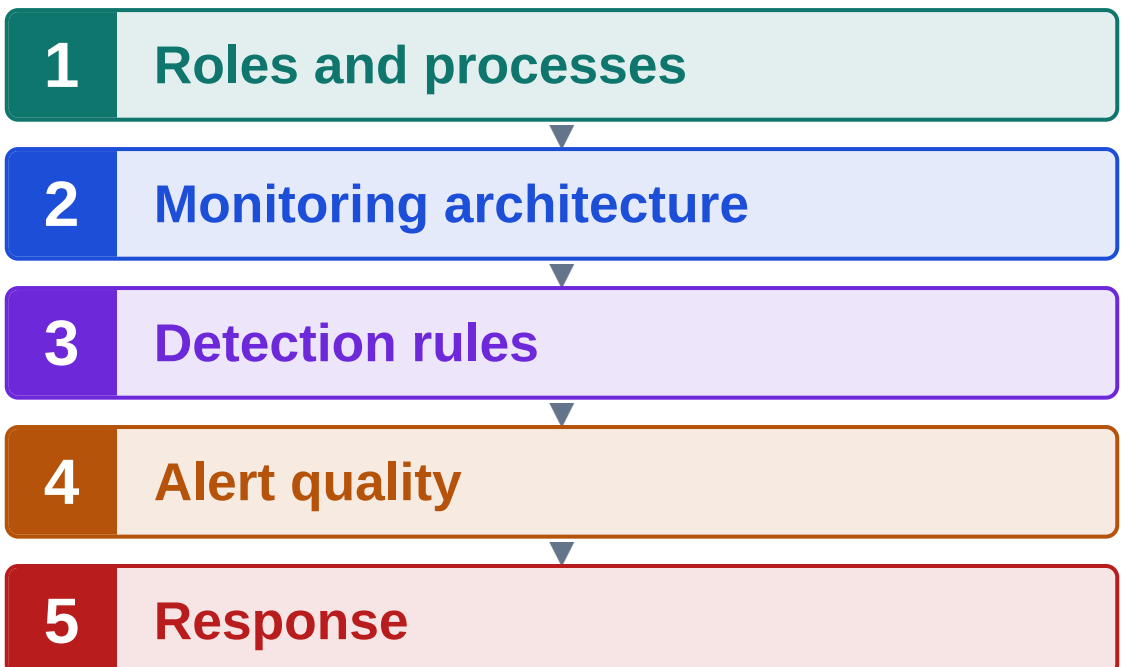
Lecture 2

# Monitoring and Response Architecture

Roles · monitoring layers · alert quality · false positives

# Lecture outline



# Event, alert, incident

**Event**

any observable occurrence in a system or network

**Alert**

notification of a specific attack: a rule has fired

**Incident**

an occurrence that threatens confidentiality, integrity or availability

Many events, few alerts, even fewer incidents

# Running example: password guessing

| Time | Address | Account | Outcome |
|---|---|---|---|
| 09:00:04 | 203.0.113.7 | anna | failure |
| 09:00:31 | 203.0.113.7 | anna | failure |
| 09:01:02 | 203.0.113.7 | anna | failure |
| 09:01:35 | 203.0.113.7 | anna | failure |
| 09:02:10 | 203.0.113.7 | anna | failure |
| 09:03:12 | 203.0.113.7 | anna | success |

→

**Alert**
5 failures within 10 minutes, then a successful login

**Incident?**
account anna is probably compromised

1

# Roles and processes

who triages alerts and in what order

# Five functions of a security operations center




Lessons from triage feed back into rules and processes

# Analyst tiers

## Tier 1

**First-line analyst**

alert triage: confirm, dismiss, escalate

## Tier 2

**Incident analyst**

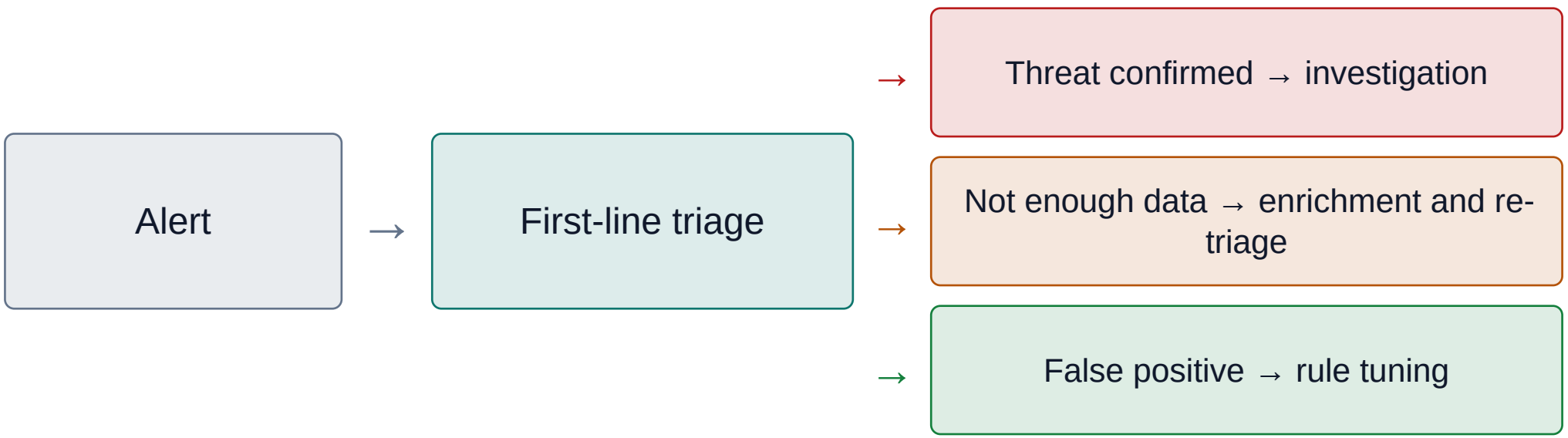
in-depth analysis, correlation, containment and eradication

## Tier 3

**Detection engineer, threat hunter**

developing and tuning rules, hunting threats without alerts

# Triage decisions



# Triage playbook: password guessing

**1**
**Address**

internal or external?

**2**
**Failures**

how many attempts, over what time?

**3**
**Account**

service, administrator, regular?

**4**
**Success after failures**

if yes — escalate to tier 2 at once

# SOC performance indicators

| Indicator | What it measures | How to read it |
|---|---|---|
| **Alerts per analyst** | Workload | Growth without more staff — misses |
| **Escalation rate** | Need for in-depth analysis | Low — not coping; high — noisy rules |
| **Time to triage** | Speed of reaction | Grows under overload |
| **Attack to detection** | Visibility | The key detection indicator |
| **Detection to remediation** | Response speed | Process maturity |

# 2

# Monitoring architecture

where data comes from and how

# Monitoring layers

### Network

scanning, external connections, data exfiltration

### Host

program execution, persistence in the system

### Application

logins, data access, access denials

### Identity

logins, privilege changes, second factor

### Cloud

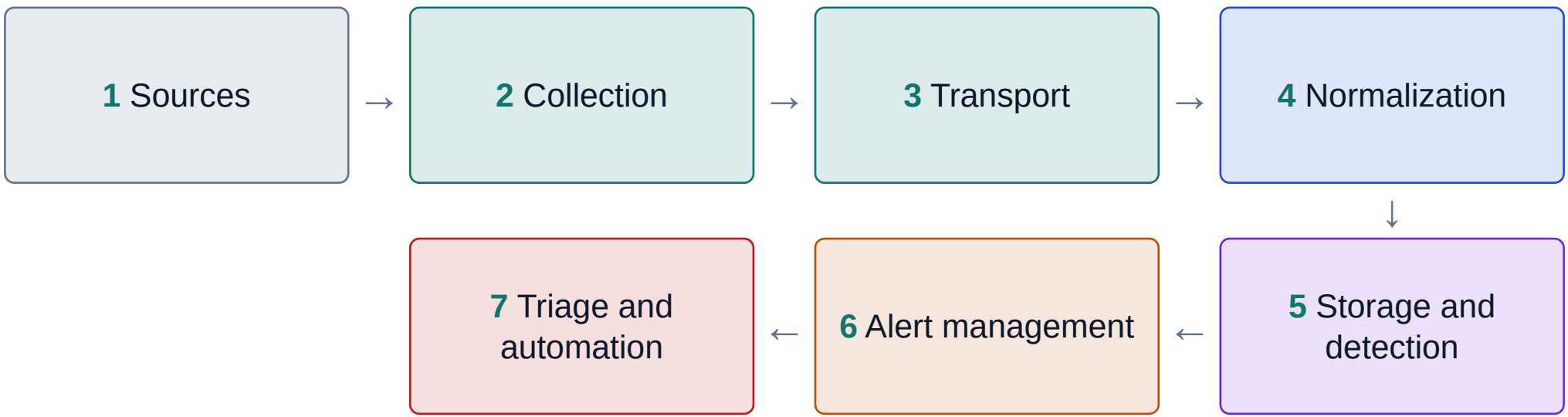
resource creation, access policy changes

# What each layer can see

| Layer | Visible | Not visible |
|---|---|---|
| **Network** | Scanning, external addresses | Content of encrypted traffic |
| **Host** | Process execution | Actions on other hosts |
| **Application** | Logins, data access | Attacks that never reached the application |
| **Identity** | Logins, privilege changes | What happens after login |
| **Cloud** | Access policy changes | Internals of managed services |

> No single layer shows the whole picture

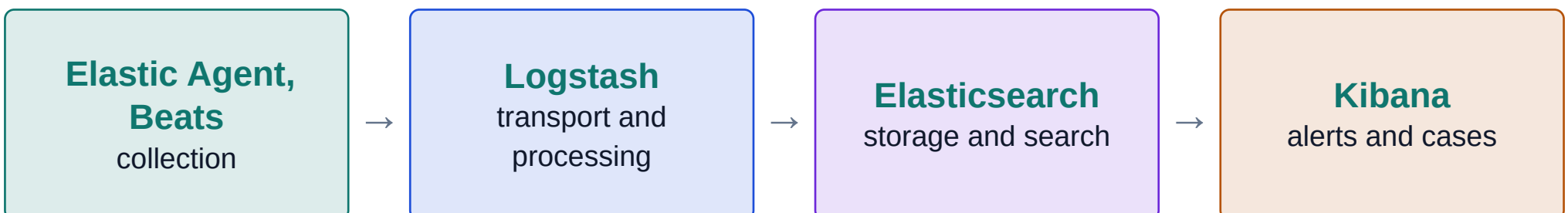
# Data flow in a monitoring system



# Monitoring system components

| Component | Function | Examples |
|---|---|---|
| **Collection** | Reading logs at the source | Fluent Bit, Filebeat, auditd |
| **Transport** | Buffered delivery | Kafka, Vector, Logstash |
| **Normalization** | Common schema | ECS, OCSF |
| **Storage and detection** | Search, applying rules | OpenSearch, Wazuh, ClickHouse |
| **Alert management** | Queue, case cards | TheHive |
| **Automation** | Response playbooks | Shuffle, Cortex |

# Example: Elastic Stack




**ECS** schema: common field names

Elastic Security: rules, alerts, cases

# Normalization: a common event schema

**Different sources**

```
Mar 12 09:00:04 sshd: Failed
password for anna from 203.0.113.7
```

```
{"user":"anna","ok":false}
```

→

| Field | Value | In ECS |
|---|---|---|
| timestamp | 2026-03-12T09:00:04Z | `@timestamp` |
| event_type | auth.login | `event.category` |
| actor.id | anna | `user.name` |
| source_ip | 203.0.113.7 | `source.ip` |
| outcome | failure | `event.outcome` |

One schema — one rule for all sources

# Enrichment: how important is it

| Asset context | Location | Reputation | Account |
| --- | --- | --- | --- |
| production server, high criticality | a country unusual for this user | address known for password guessing | belongs to an accountant |

> Context raises or lowers the severity of an alert

# Threat intelligence

| Strategic | Tactical | Operational | Technical |
|---|---|---|---|
| adversary motivation, trends | adversary techniques and campaigns | information on current campaigns | indicators: addresses, domains, hashes |
| for: management | for: detection engineers | for: response team | for: detection and protection systems |

**STIX** — format for describing intelligence: objects and relationships → **TAXII** — protocol for exchanging these objects over HTTPS

# 3

# Detection rules

how to describe an attack with a rule

# Example 1: password guessing

```yaml
title: Password guessing against an account
name: failed_login_burst
correlation:
    type: event_count
    rules: [failed_login]
    group-by: [actor.id]
    timespan: 10m
    condition: {gte: 5}
```

**rules** count failures

**group-by** separately per account

**timespan** in a 10-minute window

**condition** five or more

5 failures for anna, 09:00:04–09:02:10 → base rule selects failures → count per account over 10 minutes: 5 → 5 ≥ 5: alert at 09:02:10

# Example 2: login after a series of failures

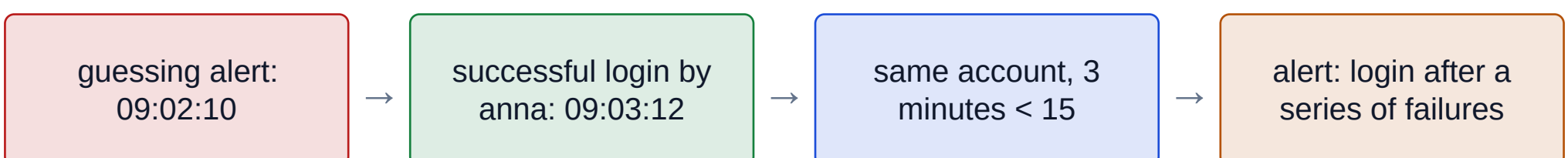
```
title: Login after a series of failures
correlation:
    type: temporal_ordered
    rules: [failed_login_burst,
            successful_login]
    group-by: [actor.id]
    timespan: 15m
```

**temporal_ordered** strict order

**rules** guessing, then login

**group-by** same account

**timespan** within 15 minutes



# The same rules in Elastic Security

| Sigma | Elastic Security | Parameters |
|---|---|---|
| **event_count** | “Threshold” rule | group by user.name, threshold 5 |
| **value_count** | “Threshold” with cardinality | source.ip, at least 8 distinct user.name |
| **temporal_ordered** | Event correlation (EQL) | sequence within 15 minutes |

```
sequence by user.name with maxspan=15m
  [ authentication where event.outcome == "failure" ] with runs=5
  [ authentication where event.outcome == "success" ]
```

# Correlation types in Sigma

**event_count**

number of events in a period

**value_count**

number of distinct field values

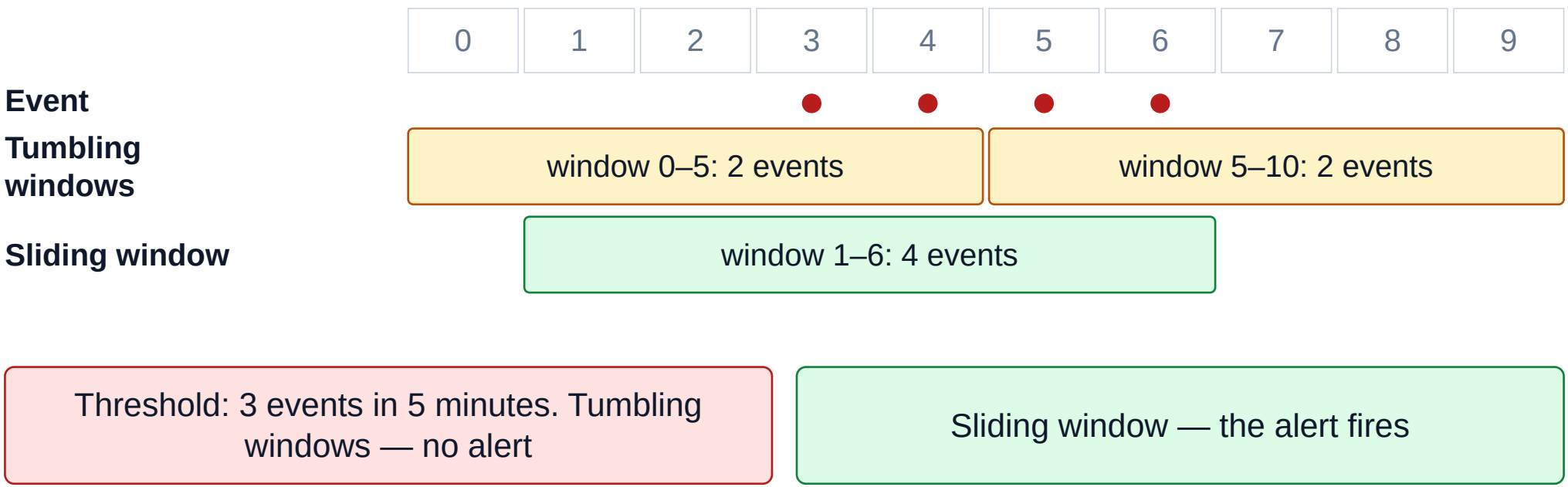
**temporal**

events in a period in any order

**temporal_ordered**

events in a given order

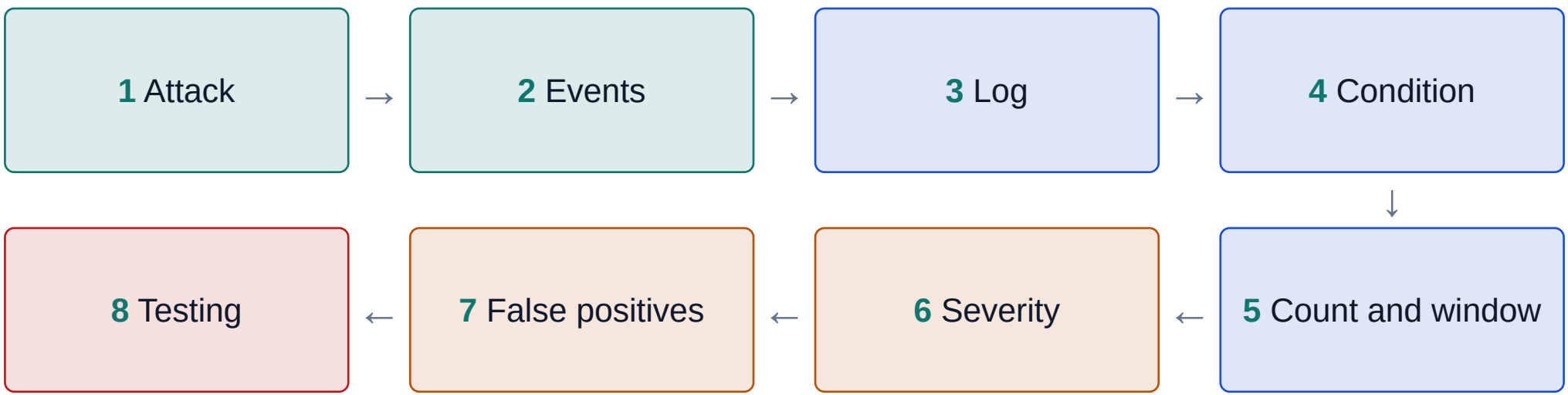
# Time windows




Threshold: 3 events in 5 minutes. Tumbling windows — no alert

Sliding window — the alert fires

# Eight steps to build a rule



# Adding up weak signals

| Weak signal | Points | ATT&CK |
|---|---|---|
| More than three failed logins | 2 | T1110 |
| Login from a new country | 2 | T1078 |
| Successful login after failures | 3 | T1110 |
| Access to an administrative interface | 1 | T1078 |
| Export of more than 1,000 records | 3 | T1041 |

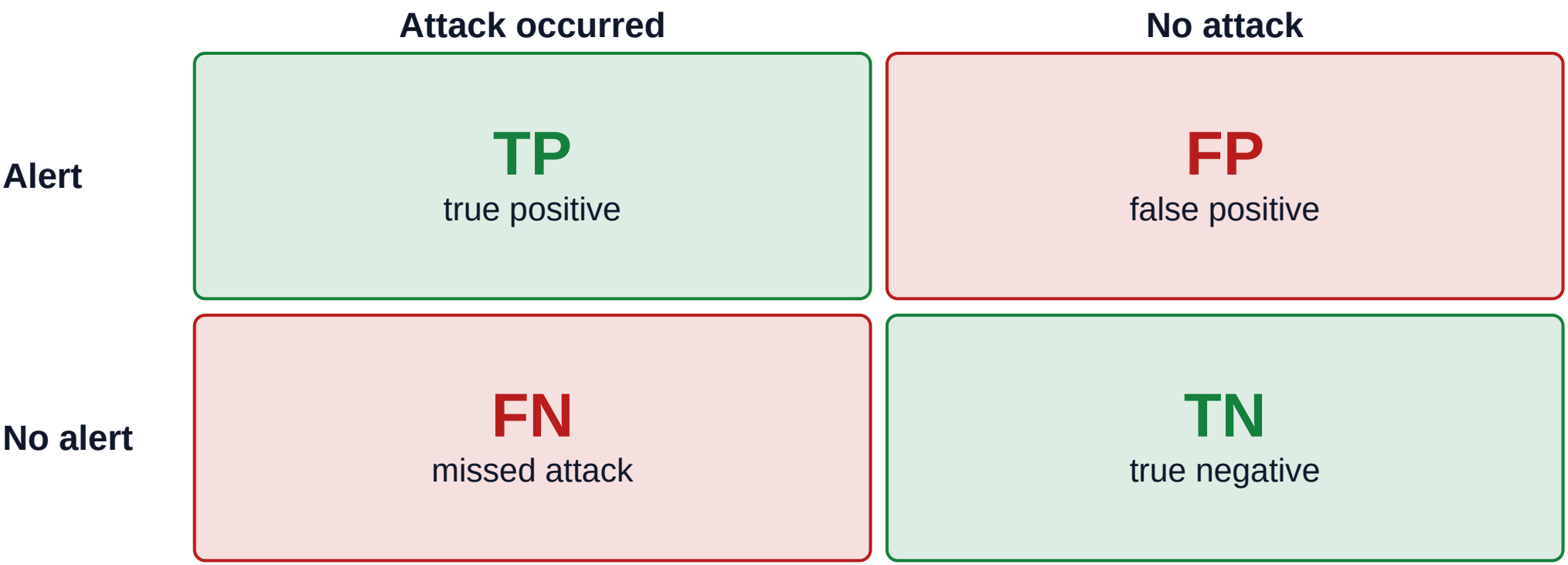
A total of at least 8 within 30 minutes — one strong alert “likely account takeover”

# 4

# Alert quality

how far alerts can be trusted

# Four outcomes of a rule



# Precision and recall

**Precision**

TP / (TP + FP)

share of true alerts among all alerts

**Recall**

TP / (TP + FN)

share of attacks found among all attacks

**40**

alerts

**30**

true (TP)

**50**

attacks in the period

Precision = 30 / 40 = 0.75 · Recall = 30 / 50 = 0.6

# Threshold: a trade-off

| Lower threshold | Higher threshold |
| --- | --- |
| Recall ↑ · precision ↓<br>more false positives | Precision ↑ · recall ↓<br>more missed attacks |

# Alert fatigue

| Generic rules | No context | No baseline | Duplicates |
| --- | --- | --- | --- |
| fire on normal behavior | unclear whether the asset is critical | any deviation looks suspicious | one attack — many alerts |

> Many false alerts — the analyst misses the real ones

# Ways to reduce false positives

| Method | Essence | Example |
|---|---|---|
| **Tuning** | Raise the threshold, exceptions | Threshold 5 → 10 |
| **Enrichment** | Asset context, reputation | Higher severity for production servers |
| **Correlation** | Combine weak signals | Points for several indicators |
| **Suppression** | Temporarily do not alert | Known scanner, with a review date |
| **Notification levels** | Low-value items go to a dashboard | Informational alerts without notifications |

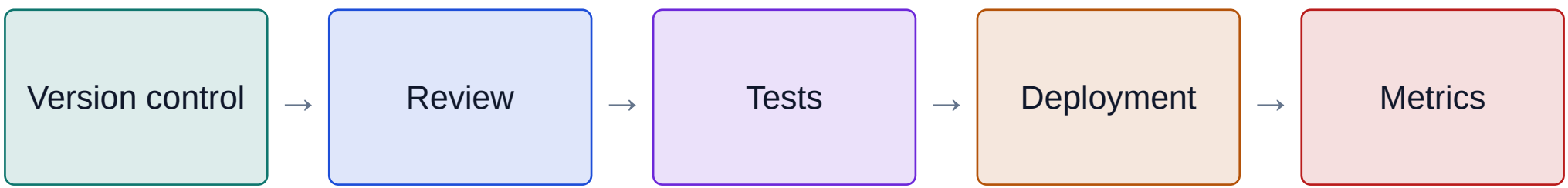
# Example: a shared office address

**Problem**
many employees mistype passwords from one address — the “5 failures” rule fires every day

→

**Solution**
exclude gateways or count failures per “address and account” pair

# Detection as code



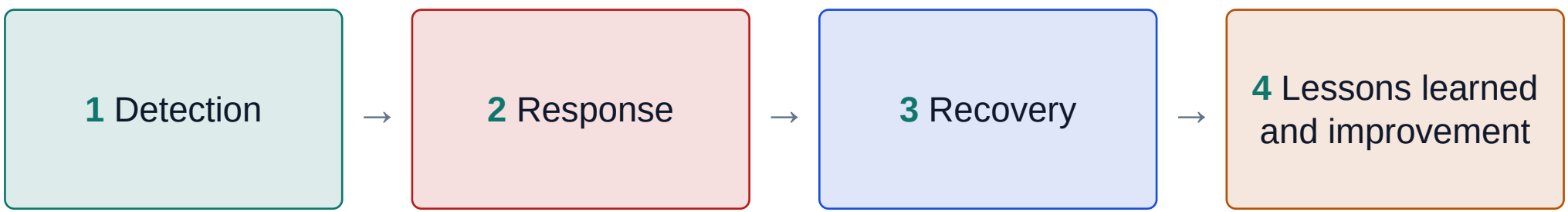

ADS framework: goal, data, logic, false positives, validation, response

5

# Response

what to do after confirmation

# Response cycle




NIST SP 800-61 Rev. 3 is built on the CSF 2.0 functions

# Automation and action risk

**Block an address**
**low risk**

executed immediately

**Lock an account**
**medium risk**

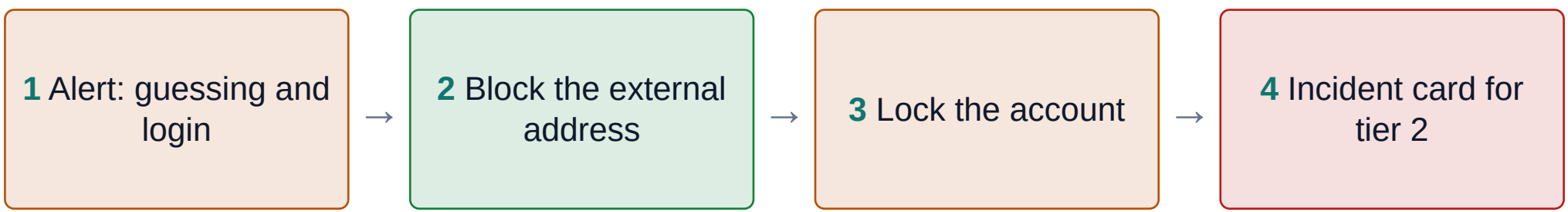
with notification and the option to undo

**Isolate a host, disable a service**
**high risk**

only with human approval

The higher the risk of an action, the more human involvement

# Playbook for the running example




Lessons learned: tune the rule, enable the second factor

# Key points

| | |
|---|---|
| **1 Roles and processes** | Three tiers; three triage decisions |
| **2 Architecture** | Several layers, common schema, enrichment |
| **3 Rules** | Sigma, sliding windows, adding up signals |
| **4 Quality** | Precision and Recall, fighting alert fatigue |
| **5 Response** | Cycle and risk-based automation |

Lecture 2

# Monitoring and Response Architecture

Roles · monitoring layers · alert quality · false positives